

INTRO AL PENETRATION TESTING DE APLICACIONES WEB

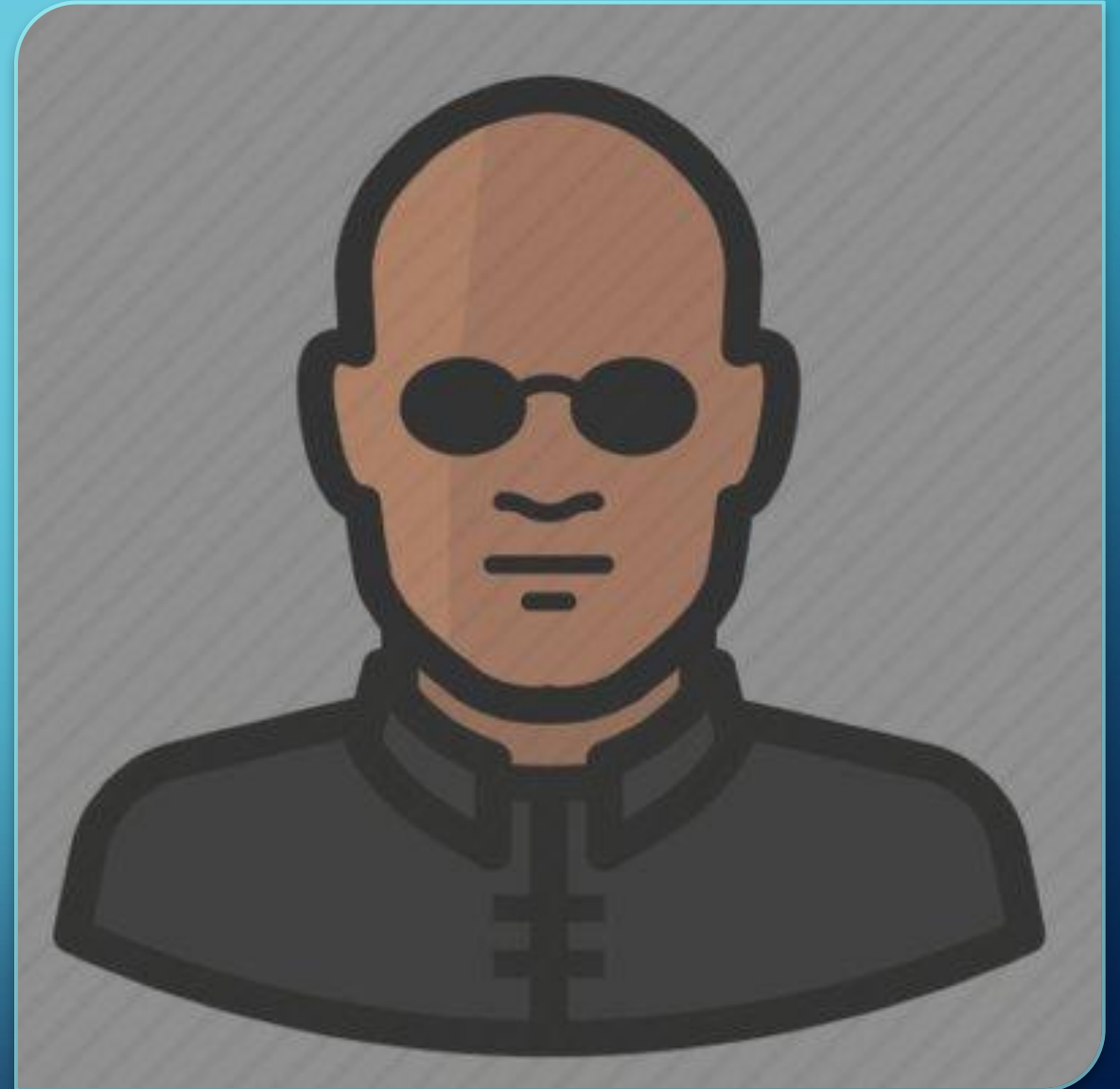


MINISTERIO DE CIENCIA,
INNOVACIÓN, TECNOLOGÍA
Y TELECOMUNICACIONES

GOBIERNO
DE COSTA RICA

BIO

- Raga también c.c. Luis Diego Raga
- Sr. Penetration Tester
- Cloud Security, DDoS, WAF, Bot Management, CDN, Networking (FWs, VPN, IPS), Incident Response
- LinkedIn: [Luis Diego Raga](#)
- Discord: dc506.org
- Twitter: [@Ragab0t](#)
- Blog: [blog.ragab0t.com](#)



AGENDA

- Objetivos
- Proceso
- Metodología
- Desafíos
- Ética
- Demo
- Recursos



WEB APP PENTESTING - OBJETIVOS

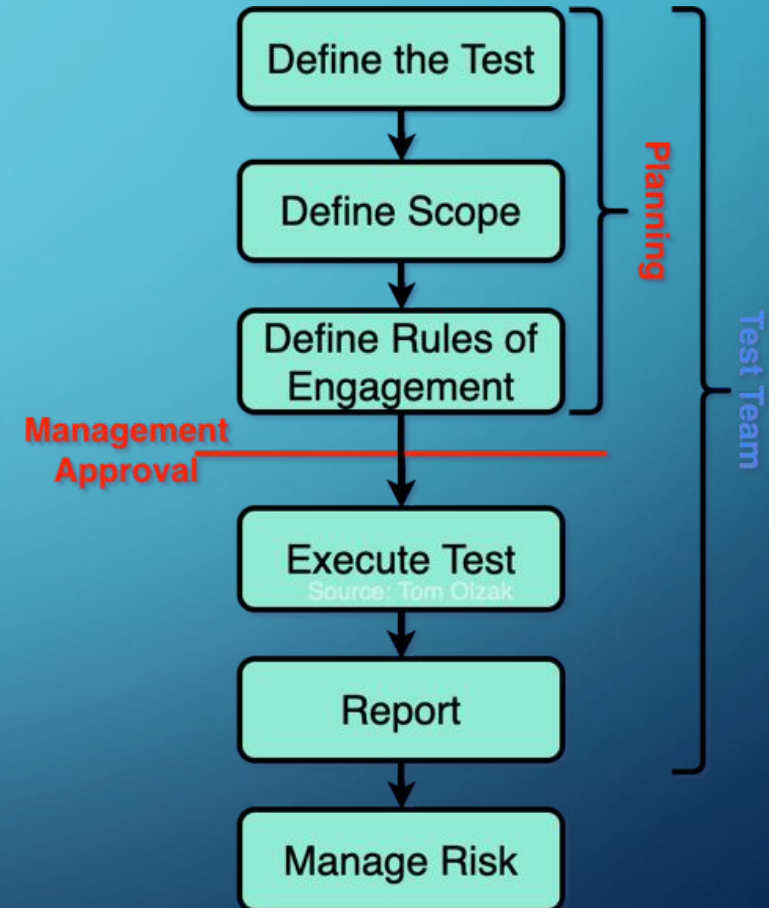
Un Pentest es un proyecto que tiene los siguientes objetivos:

- Identificar vulnerabilidades que podrían ser explotadas por atacantes malintencionados
- Garantizar que las aplicaciones web sean seguras y estén mejor equipadas contra ataques
- Cumplir con requisitos de cumplimiento y certificaciones
- Probar la madurez del programa de seguridad en tema de respuesta a incidentes



WEB APP PENTESTING: PROCESO

- Definir el motivo del test
- Definir el alcance
- Definir Rules of Engagement
- Kickoff
- Recolección de información
- Identificación de vulnerabilidades
- Explotación de vulnerabilidades
- La generación y presentación de informes
- Re-Tests



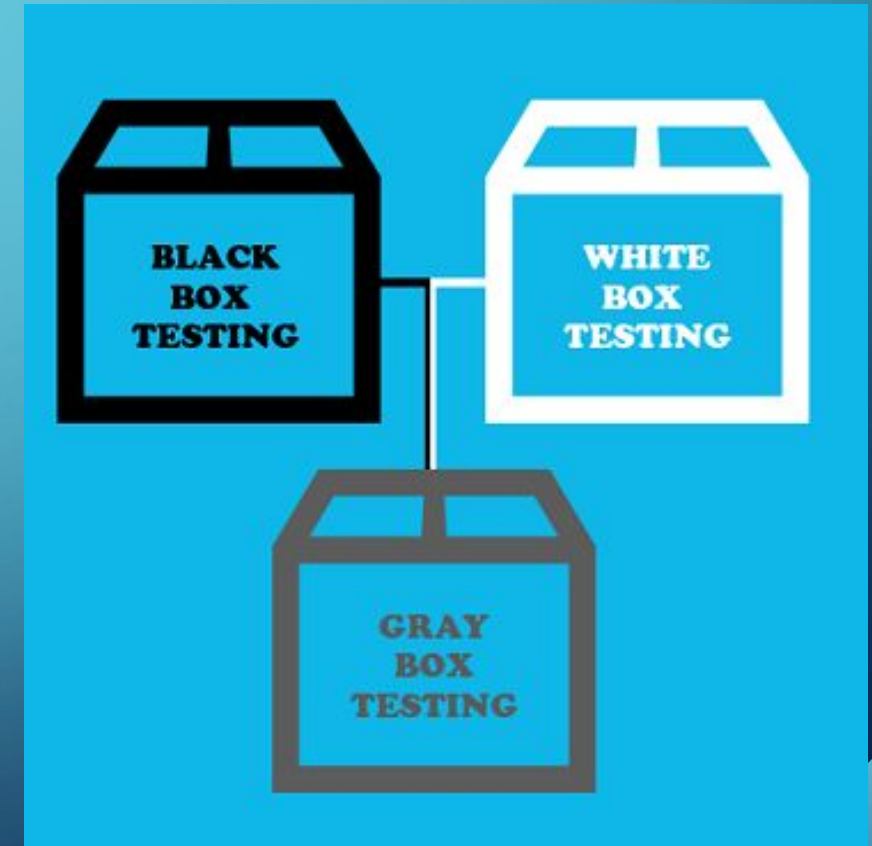
WEB APP PENTESTING: TIPOS

- Basados en la información provista:

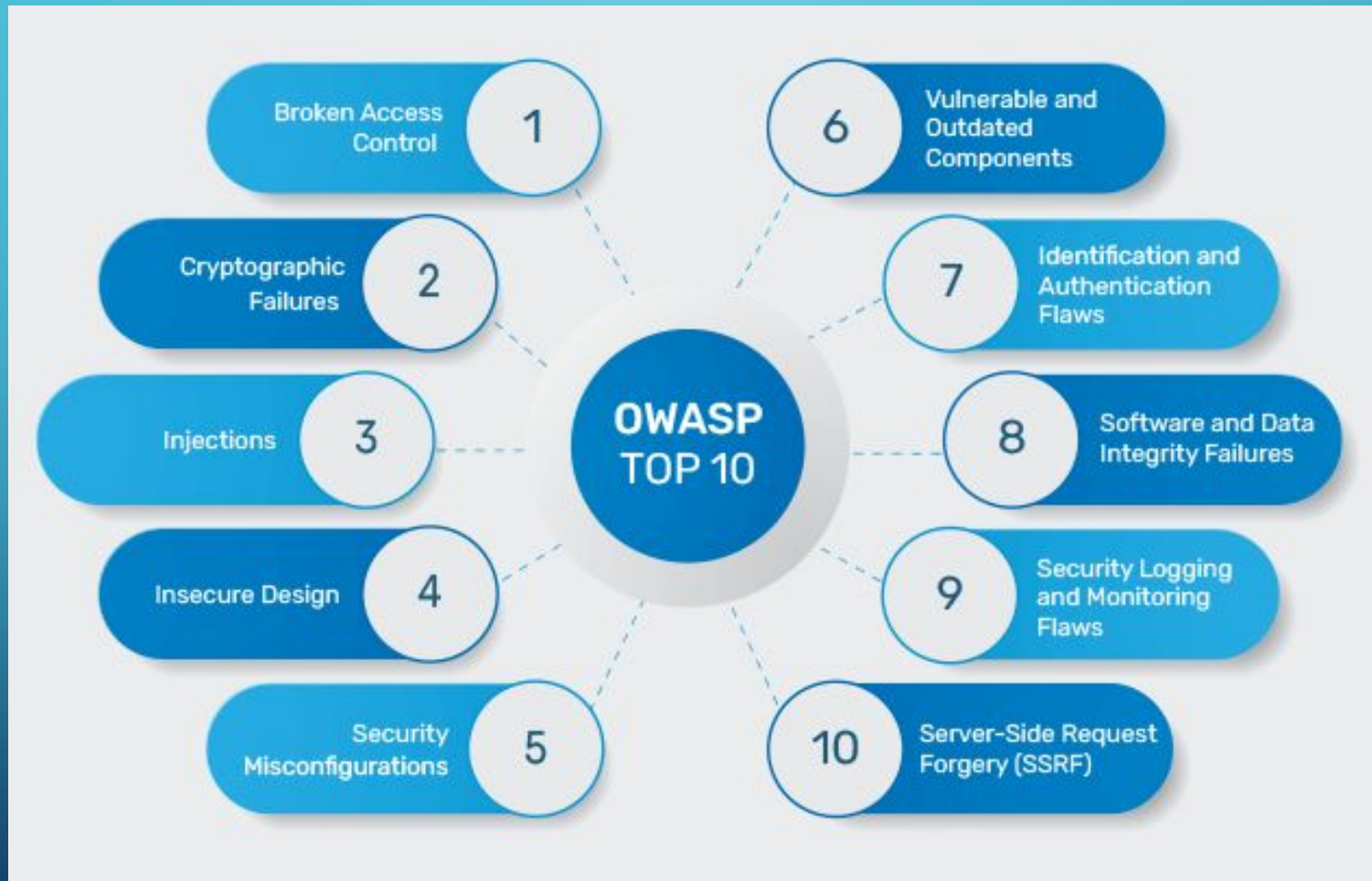
- Black Box
- Gray Box
- White Box

- Basados en el alcance

- Incremental
- Full

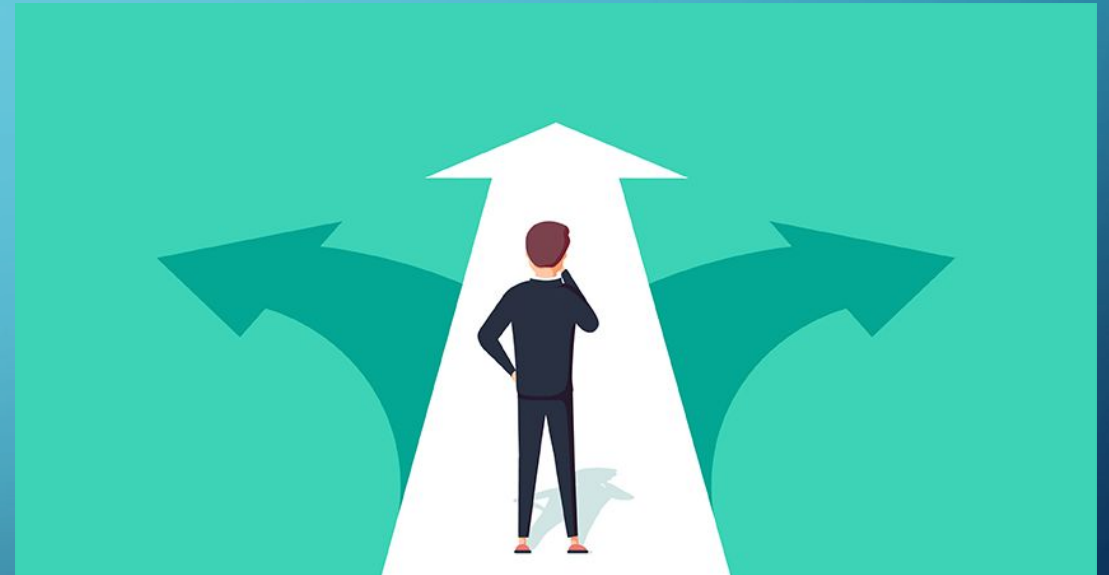


TIPOS DE VULNERABILIDADES



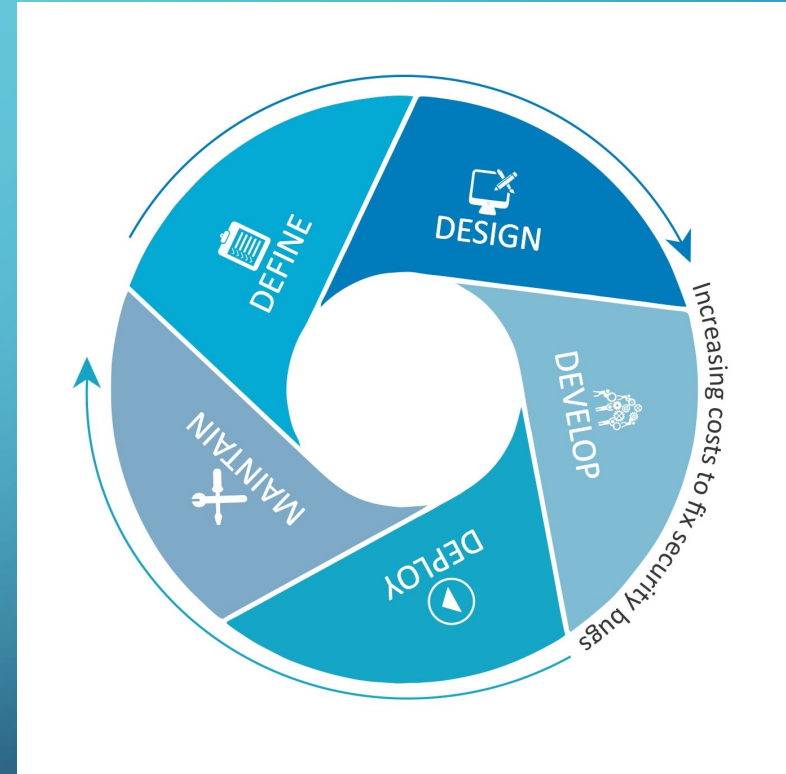
METODOLOGÍAS - MARCOS DE REFERENCIA

- OWASP Top 10
- OWASP Top 10 API
- OWASP Top 10 Mobile
- SANS Top 25



GUÍAS - OWASP TESTING GUIDE

- Guia desarrollada por OWASP
- Proporciona una metodología estructurada
- Incluye mejores prácticas, riesgo, planificación y ejecución de pruebas, y presentación de resultados
- Incluye recomendaciones de herramientas y técnicas utilizadas



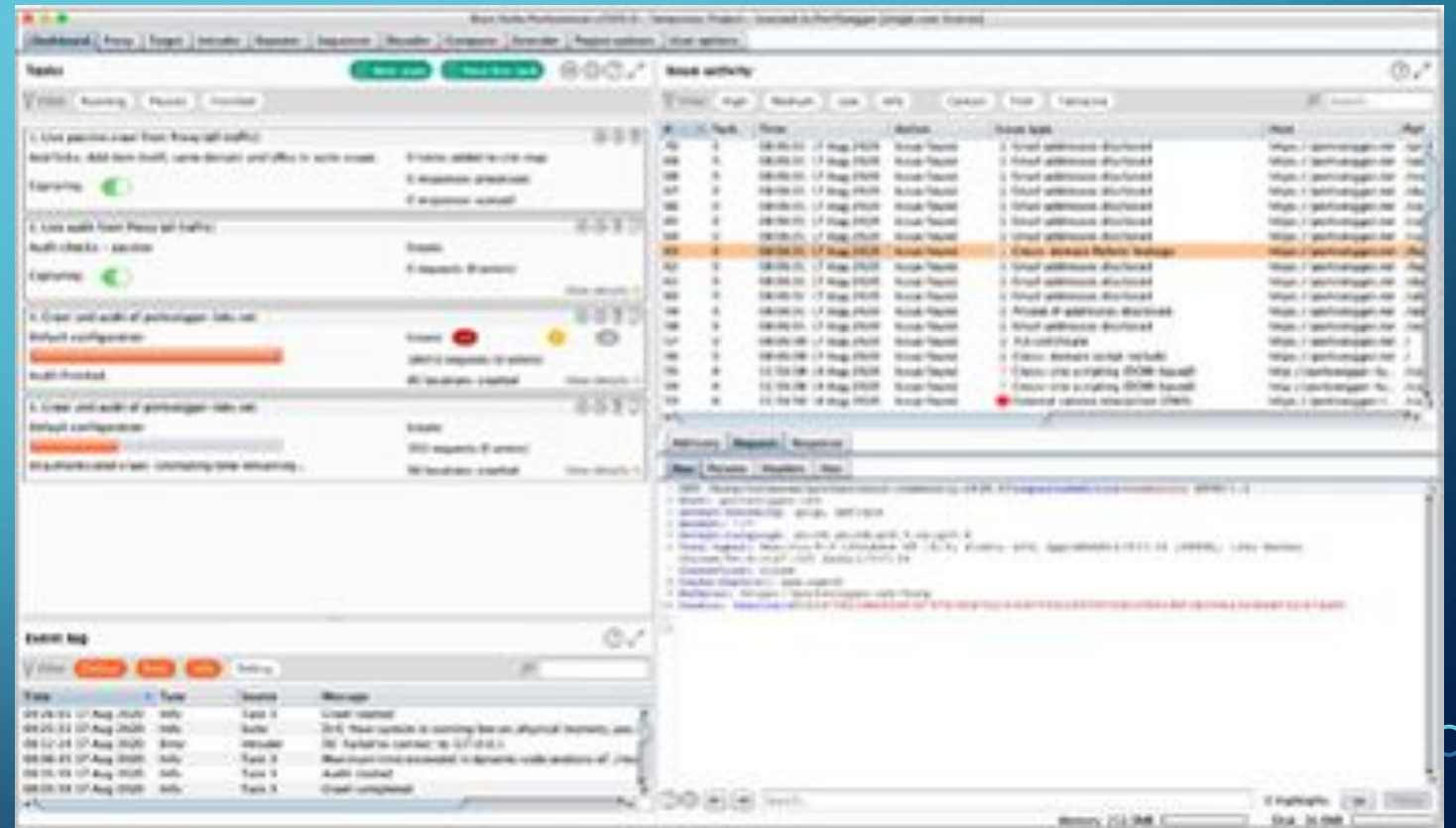
PREPARACIÓN

- Disponer de ambientes de prueba
- Contar con contacto técnico
- Accesos (VPN, Allow List, Credenciales)
- Backups de la base de datos (prod)
- Plan de respuesta a incidentes



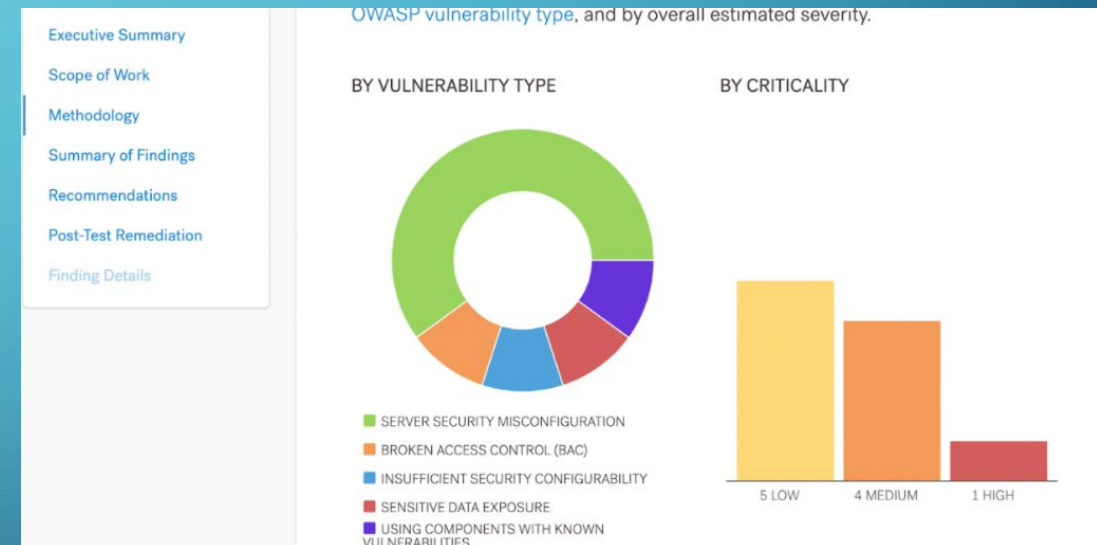
EJECUCIÓN - HERRAMIENTAS

- WhatWeb
- Wappalizer
- FFUF
- Burp Suite
- ZAP
- SQLMap
- WPScan
- Curl
- Metasploit



REPORTE

- “Nos pagan por hacer reportes, no por hackear cosas”
- Debe incluir cuando mínimo:
 - Resumen ejecutivo
 - Alcances y metodología
 - Detalles técnicos de cada vulnerabilidad encontrada
 - Recomendaciones



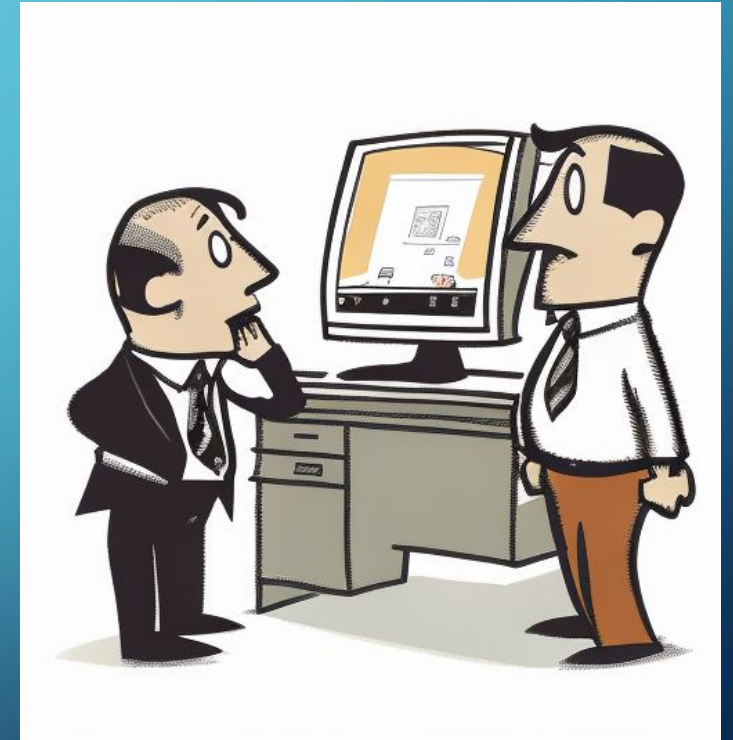
MITIGACIÓN

- Se debe tomar en cuenta la severidad de la vulnerabilidad.
- Posibles soluciones
 - Parches de seguridad
 - Actualizaciones de software hasta
 - Cambios en la configuración de la aplicación
- Es importante probar que la mitigación sea efectiva

Rating	CVSS Score
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

DESAFÍOS

- Acceso a la información solicitada (credenciales, ambientes, conectividad)
- Disponibilidad del cliente para responder consultas a lo largo del test
- Limitación con respecto a herramientas en ambientes muy seguros
- Mantenerse al día en tema de técnicas, ataques y metodologías

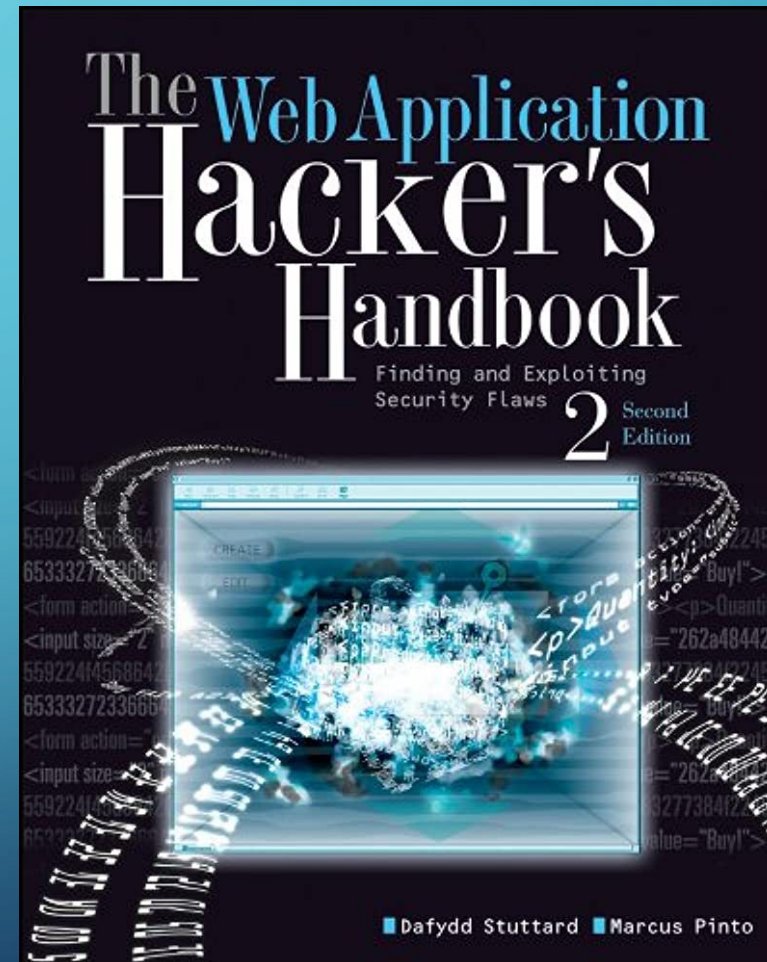


The image features a blue gradient background with decorative circuit-like lines in the corners. These lines, in shades of light blue and white, form various geometric shapes and paths, some ending in small circles, resembling a stylized electronic circuit board.

DEMO

RECURSOS

- Online Labs:
 - Web Security Academy
 - Hack the Box / HTB Academy
 - Try Hack Me
 - Pentester Lab
- Vulnerable Web Apps:
 - Juice Shop
 - Web Goat
 - DVWA
- Youtube:
 - InsiderPHD
 - NahamSec
 - The Cyber Mentor
 - The XSS Rat
 - S4vitar
 - DC506



CERTIFICACIONES

- SANS: GWAPT
- eLearn:
 - eWPT
 - eWPTX
- Offsec:
 - OSCP
 - OSPA
 - OSWE
- Portswigger: Burp Suite Certified Practitioner
- Hack the Box: Bug Bounty Hunter



CONECTEMOS :)



Luis Diego Raga
Sr. Penetration Tester, X-Force Red |
DC11506 Admin Team | Hack the Bo...

